

1. Titre du projet

- **Variation 1 :** Architecture Zero Trust : Réduction de la surface d’attaque par une gestion d’identités et de privilèges basée sur le modèle IAM/PIM.
- **Variation 2 :** Conception et implémentation d’un socle d’authentification Zero Trust pour améliorer la conformité et la sécurité des actifs informationnels.
- **Variation 3 :** Intégration d’une solution IAM/PIM Open Source comme pilier d’une stratégie de sécurité Zero Trust : De la théorie au Proof of Concept.

2. Alternatives architecturales (Cloud vs On-Premise)

Le choix de la plateforme de gestion des identités et des accès (IAM) est un pilier fondamental de toute stratégie Zero Trust. Deux approches principales s'opposent :

- **Solution Cloud (SaaS - Software as a Service) :** Des plateformes comme Microsoft Entra ID (Azure AD), Okta ou Duo offrent des services IAM complets, managés et hautement disponibles. L'enjeu principal réside dans l'externalisation de la gestion de l'identité, impliquant une dépendance à un fournisseur tiers. Bien que le déploiement soit accéléré et la charge opérationnelle réduite, cela pose des questions de souveraineté des données, de flexibilité (enfermement propriétaire ou *vendor lock-in*) et de coûts récurrents (modèle par abonnement). L'interopérabilité est excellente mais souvent contrainte à l'écosystème du fournisseur.
- **Solution On-Premise / Auto-hébergée :** Des solutions Open Source comme Authentik, Keycloak ou FreeIPA permettent de construire une infrastructure IAM/PIM sur ses propres serveurs (physiques ou virtualisés) ou sur une infrastructure IaaS (Infrastructure as a Service) privée. Cette approche garantit une **souveraineté totale des données** et une flexibilité maximale pour l'intégration et la personnalisation. Cependant, elle induit une complexité de déploiement et de maintenance significativement plus élevée, nécessitant des compétences internes en administration système, en sécurité et en gestion de bases de données. La haute disponibilité et la scalabilité deviennent la responsabilité de l'équipe projet.

3. Étude comparative des solutions

Le tableau suivant synthétise les différences majeures entre les deux modèles.

Critère	Solution Commerciale (SaaS - ex: Entra ID)	Solution Open Source (Auto-hébergée - ex: Authentik)
Coût (TCO)	Coûts d'abonnement récurrents (OPEX), prévisibles mais potentiellement élevés à grande échelle.	Coût initial faible (licences gratuites), mais coûts cachés importants (CAPEX/OPEX) : matériel, maintenance, expertise humaine.

Critère	Solution Commerciale (SaaS - ex: Entra ID)	Solution Open Source (Auto-hébergée - ex: Authentik)
Flexibilité	Modérée. Les fonctionnalités sont définies par le fournisseur. Personnalisation limitée aux options de l'API et de la console.	Très élevée. Le code source est accessible. Intégrations sur-mesure et adaptations profondes sont possibles.
Complexité déploiement	Faible. Configuration via des interfaces graphiques assistées. Pas de gestion d'infrastructure sous-jacente.	Élevée. Nécessite le provisionnement de serveurs, la configuration de bases de données, réseaux, et la sécurisation de l'ensemble.
Souveraineté des données	Limitée. Les données d'identité et les métadonnées de connexion sont stockées et traitées par un tiers.	Totale. L'organisation contrôle entièrement le stockage physique et logique des données sensibles.
Support	Support professionnel garanti par le fournisseur, avec des SLA (Service Level Agreements) définis.	Support communautaire. Le support professionnel est souvent une option payante via des intégrateurs tiers.

4. La solution retenue : Le duo Authentik (IAM) & HashiCorp Boundary (PAM)

Pour répondre aux exigences d'une architecture Zero Trust moderne, le projet s'articulera autour de l'intégration de deux solutions Open Source complémentaires, chacune spécialisée dans son domaine : **Authentik** pour la gestion des identités et des accès (IAM) et **HashiCorp Boundary** pour la gestion des accès à privilèges (PAM).

1. Comprendre le rôle de chaque brique

- **Authentik (L'IAM) est la "Porte d'entrée principale" :**
 - **Son rôle :** Répondre à la question : "Es-tu vraiment la personne que tu prétends être ?"
 - **Fonctions clés :** Il gère l'annuaire central des utilisateurs, vérifie les mots de passe, impose l'authentification multifacteur (MFA) et évalue le contexte de la connexion (ex: localisation de l'IP, heure de la journée).
 - **Sa limite :** Une fois l'identité vérifiée, Authentik n'est pas conçu pour créer des tunnels sécurisés vers des infrastructures comme des serveurs Linux (SSH) ou des bases de données.
- **HashiCorp Boundary (Le PAM) est le "Coffre-fort interne" :**
 - **Son rôle :** Répondre à la question : "Maintenant que tu es à l'intérieur, à quelles ressources critiques as-tu le droit d'accéder, et pour combien de temps ?"
 - **Fonctions clés :** Il gère l'accès *Just-In-Time* (JIT) en ouvrant des connexions réseau éphémères (sessions TCP, SSH, RDP) sans jamais exposer les ports des serveurs cibles sur le réseau. L'accès se fait via un proxy dynamique.
 - **Sa limite :** Boundary ne gère pas les identités ni les mots de passe. Il doit s'appuyer sur un système tiers de confiance pour savoir qui est l'utilisateur.

2. Comment les deux fonctionnent ensemble (Le Flux Zero Trust)

L'intérêt majeur du projet réside dans l'intégration de ces deux briques via un protocole de fédération standard (OIDC).

- **Délégation d'identité (Fédération) :** Boundary est configuré pour ne jamais gérer de mot de passe. Il délègue systématiquement l'authentification à Authentik, qui agit en tant que **Fournisseur d'Identité** (Identity Provider - IdP).
- **L'expérience utilisateur typique :**
 1. Un administrateur souhaite accéder à une base de données de production.
 2. Il se connecte à Boundary (via le client CLI ou l'interface web).
 3. Boundary le redirige automatiquement vers la page de connexion d'Authentik.
 4. L'utilisateur s'authentifie sur Authentik (login, mot de passe, MFA). Les politiques d'accès conditionnel d'Authentik sont évaluées à ce moment.
 5. Si l'authentification réussit, Authentik renvoie un "jeton de confiance" (JWT) à Boundary, confirmant l'identité de l'utilisateur et ses appartenances (groupes).
 6. Boundary vérifie le jeton, identifie l'utilisateur et ses permissions, puis lui ouvre un tunnel TCP temporaire et sécurisé vers la base de données pour une durée limitée (ex: 1 heure), conformément au principe du moindre privilège.

5. Étapes de développement (Roadmap)

Le plan de réalisation du PoC se décompose comme suit :

1. Phase 1 - Audit et Conception :

- Définir le périmètre du laboratoire : 1-2 applications web (ex: Grafana) et 1-2 cibles d'infrastructure (ex: un serveur SSH, une base de données PostgreSQL).
- Cartographier les flux d'accès et rédiger les politiques de sécurité cibles (ex: "Seuls les administrateurs peuvent accéder au serveur SSH de production, après validation MFA et pour une durée de 1h maximum").

2. Phase 2 - Déploiement du socle IAM (Authentik) :

- Mise en place de l'environnement de virtualisation (Docker).
- Déploiement et configuration de base d'Authentik (utilisateurs, groupes).
- Intégration d'une application web avec Authentik (via Outpost) pour valider le SSO.

3. Phase 3 - Déploiement du socle PAM (HashiCorp Boundary) :

- Déploiement de Boundary en mode dev ou via Docker.
- Configuration initiale : création d'une organisation, d'un projet.
- Enregistrement des cibles d'infrastructure (ex: le serveur SSH) dans Boundary.

4. Phase 4 - Fédération d'Identité OIDC (Authentik + Boundary) :

- Configuration d'Authentik en tant que fournisseur d'identité OIDC.

- Configuration de Boundary pour utiliser Authentik comme méthode d'authentification externe.
- Test du flux de connexion : `boundary login` doit rediriger vers Authentik pour l'authentification.

5. Phase 5 - Implémentation des accès à privilèges JIT :

- Définition des rôles et permissions dans Boundary, en liant les groupes d'utilisateurs provenant d'Authentik.
- Démonstration d'un accès sécurisé à une cible (ex: `boundary connect ssh ...`).
- Validation que la session est bien éphémère et que les identifiants de la cible ne sont jamais exposés à l'utilisateur.

6. Phase 6 - Audit et Reporting :

- Corrélation des journaux d'audit d'Authentik (qui s'est connecté ?) avec ceux de Boundary (à quoi a-t-il accédé ?).
- Mise en évidence de la traçabilité complète du cycle de vie de l'accès.

6. Fonctionnalités clés à implémenter (Use Cases)

Pour valider la pertinence de la solution, les cas d'usage suivants devront être développés :

- **UC-01 : SSO et MFA pour Application Web** : Un utilisateur accède à un dashboard Grafana. Il est redirigé vers Authentik, doit s'authentifier et valider un second facteur (MFA). Authentik confirme son identité et l'autorise à accéder à Grafana.
- **UC-02 : Accès Conditionnel basé sur le Contexte (IAM)** : Le même accès à Grafana est tenté depuis une adresse IP non approuvée. Authentik bloque la tentative d'authentification en amont, même si le mot de passe est correct.
- **UC-03 : Accès Sécurisé à un Serveur SSH (PAM)** : Un administrateur système exécute une commande `boundary connect ssh ....` Il est authentifié via Authentik, et Boundary lui ouvre un tunnel SSH vers le serveur cible sans exposer le port 22 de celui-ci et sans que l'administrateur n'ait besoin de gérer une clé SSH privée.
- **UC-04 : Accès à une Base de Données Just-In-Time (JIT)** : Une analyste de données a besoin d'accéder à une base PostgreSQL. Via Boundary, elle obtient une connexion directe à la base de données pour une session de 30 minutes. À la fin du temps imparti, la session est automatiquement terminée par Boundary.
- **UC-05 : Audit Inter-Systèmes** : Démontrer qu'il est possible de retrouver dans les journaux d'Authentik la tentative de connexion de l'administrateur (UC-03) et de corréler son horodatage avec la session SSH ouverte dans les journaux de Boundary.